W14D4 - Authentication cracking con Hydra

Studente: Riccardo Luzzi

Corso: Cyber Security

Sistema utilizzato: Kali Linux e Metasploitable 2

Strumenti utilizzati: Hydra, OpenSSH, vsftpd, Nmap, VirtualBox, pfSense

Target: Kali - 192.168.50.100; Metasploitable - 192.168.51.101

Scenario di rete: Kali 192.168.50.100 e Metasploitable 192.168.51.101 su reti differenti, collegate tramite pfSense

Introduzione

L’obiettivo del W14D4 era configurare alcuni servizi di rete e utilizzare Hydra per verificare l’autenticazione con password deboli. Ho iniziato su Kali con il servizio SSH, creando un utente di prova e controllando l’accesso prima di effettuare il test con un dizionario. Ho poi ripetuto la procedura con FTP, installando il server vsftpd e verificandone la configurazione.

Ho svolto anche la parte facoltativa su Metasploitable 2, raggiungibile tramite pfSense da una sottorete differente. Le credenziali impiegate erano note e destinate al laboratorio; tutte le prove sono state eseguite sulle macchine virtuali dell’esercitazione.

1. Verifica e avvio del servizio SSH

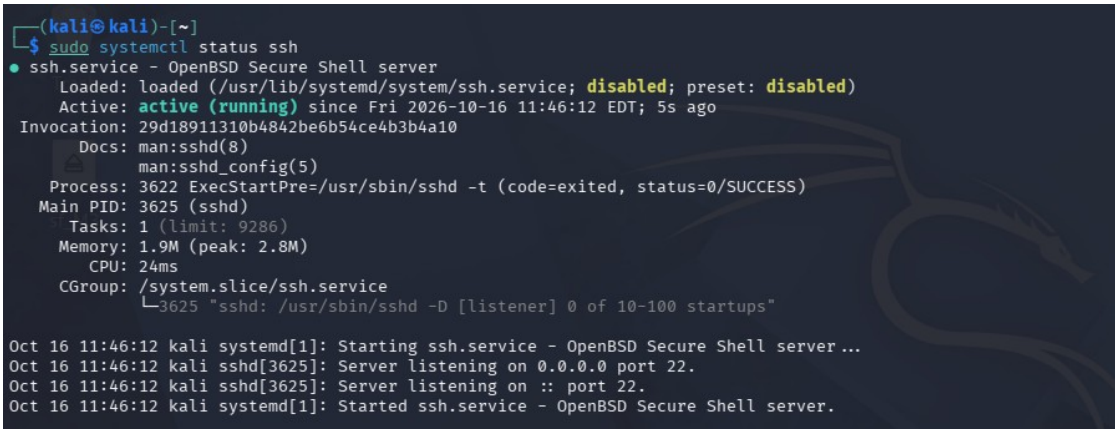
Ho controllato lo stato del servizio SSH su Kali: OpenSSH era già installato ma risultava inattivo. L'ho avviato tramite systemctl e ho verificato che fosse in esecuzione e in ascolto sulla porta 22. Il servizio è rimasto disabilitato all'avvio automatico, cosa che non impediva lo svolgimento della prova.

- sudo systemctl status ssh
- sudo systemctl start ssh
- sudo systemctl status ssh

Figura 1 - Stato iniziale del servizio SSH, inattivo



Figura 2 - Servizio SSH attivo e in ascolto sulla porta 22



2. Creazione dell'utente e accesso SSH

Per il test ho creato l'utente test_user, assegnandogli la password testpass come indicato nella procedura di laboratorio. Con id ho verificato che l'account esistesse, poi ho effettuato un collegamento SSH verso la stessa Kali, all'indirizzo 192.168.50.100. Dopo aver accettato la chiave del server, l'accesso è riuscito.

- sudo adduser test_user
- id test_user
- ssh test_user@192.168.50.100

Figura 3 - Creazione dell'utente test_user e impostazione della password

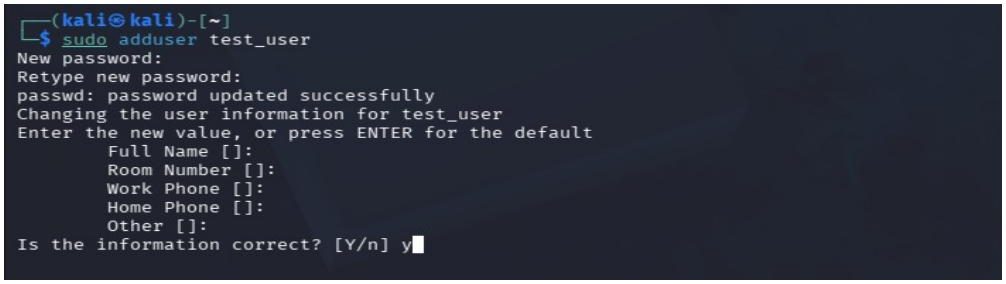


Figura 4 - Verifica dell'account con id test_user

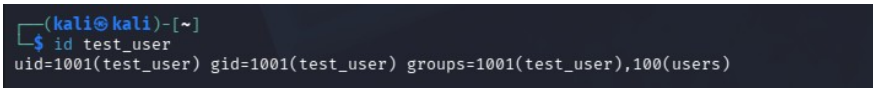
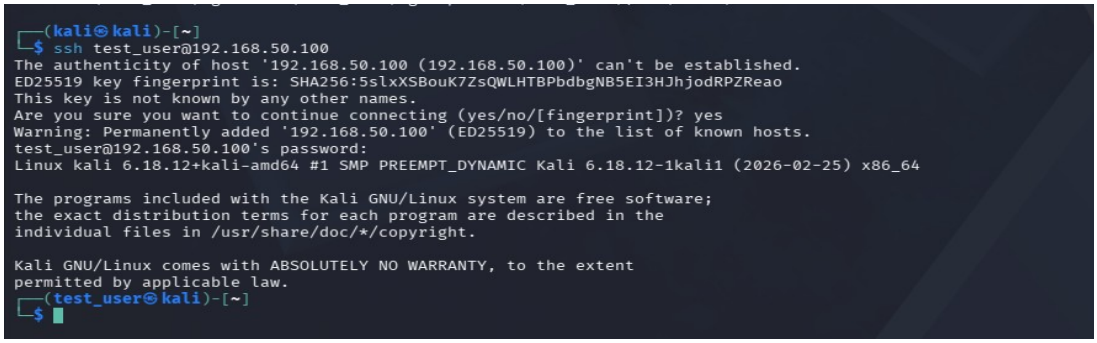


Figura 5 - Connessione SSH effettuata con test_user



3. Preparazione di Hydra e delle wordlist

Hydra era già installato nella versione 9.6. Ho preparato la cartella /home/kali/Epicode/W14D4 e al suo interno due file, usernames.txt e passwords.txt, contenenti quattro valori ciascuno. Ho inserito anche la coppia test_user / testpass, in modo da verificare se venisse individuata dal programma.

- mkdir -p /home/kali/Epicode/W14D4
- cd /home/kali/Epicode/W14D4
- cat usernames.txt
- cat passwords.txt
- ls -lh

Figura 6 - Creazione e verifica della cartella W14D4

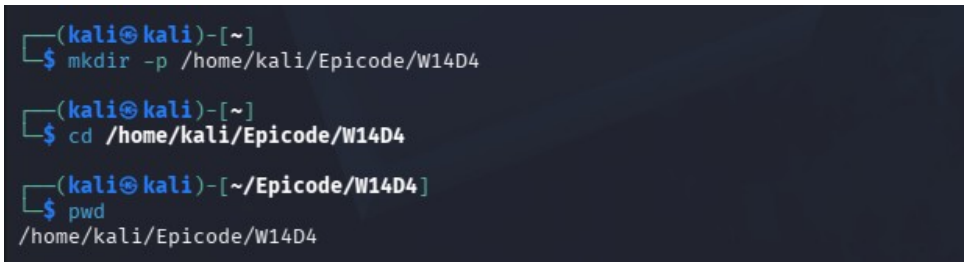
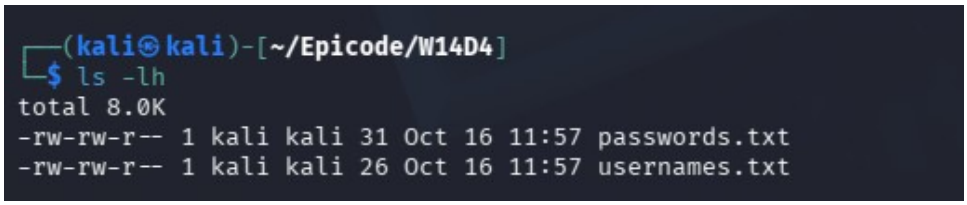


Figura 7 - Contenuto dei dizionari di utenti e password



Figura 8 - Verifica dei due file con ls -lh

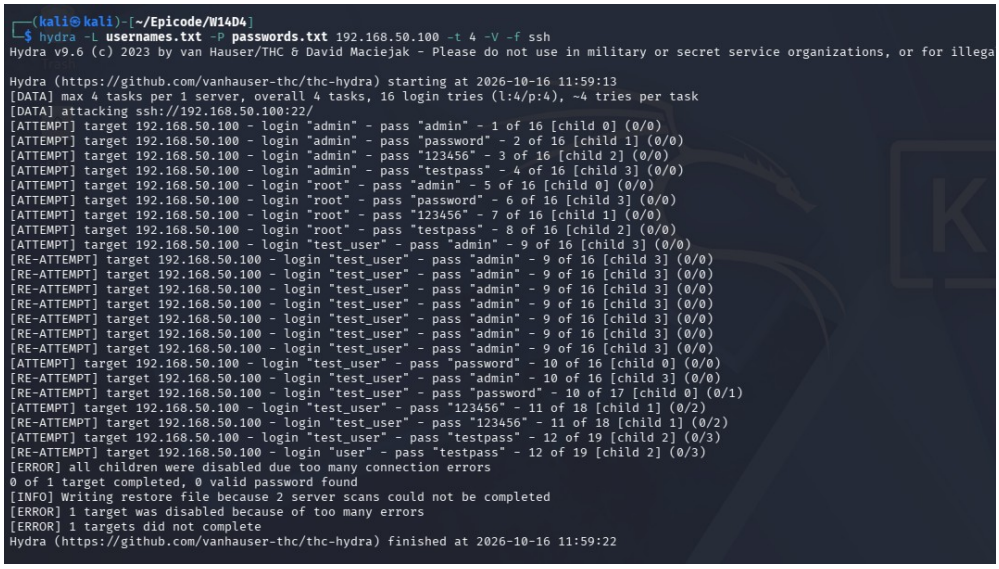


4. Primo test SSH e analisi dell'errore

Nel primo tentativo ho indicato entrambi i dizionari, ottenendo 16 combinazioni, e ho impostato quattro connessioni parallele. Hydra ha iniziato il test ma, dopo diversi messaggi RE-ATTEMPT, non è riuscito a completarlo e ha segnalato troppi errori di connessione. Non aveva trovato alcuna password valida.

- hydra -L usernames.txt -P passwords.txt 192.168.50.100 -t 4 -V -f ssh

Figura 9 - Primo test Hydra SSH interrotto per errori di connessione



Ho controllato i log di OpenSSH con journalctl. Il messaggio srclimit_penalise indicava una penalizzazione di 18 secondi per ripetuti tentativi di autenticazione falliti; nei log erano presenti anche connessioni rifiutate. I log hanno quindi confermato che il blocco dipendeva dalla protezione di OpenSSH e non dall'indirizzo IP.

- sudo journalctl -u ssh --since "2026-10-16 11:58:00" --until "2026-10-16 12:01:00" -no-pager

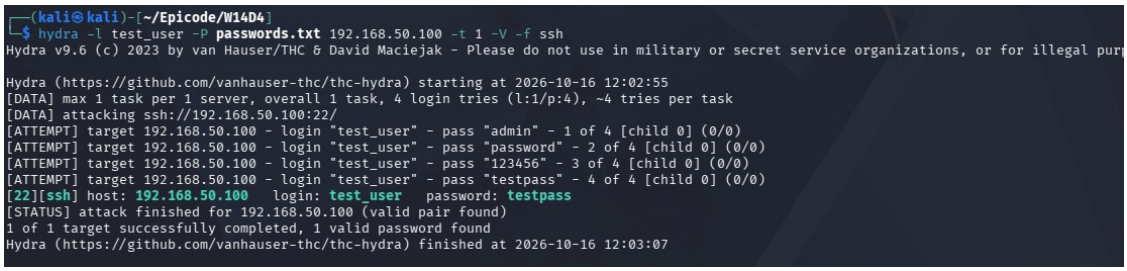
Link --> **Log Open SSH**

5. Secondo test SSH con Hydra

Per ripetere la verifica senza generare tanti tentativi falliti ho usato un solo username e una sola connessione parallela. Questa volta Hydra ha eseguito quattro tentativi e ha trovato la password testpass dell'utente test_user. Il confronto fra i due tentativi è interessante anche perché mostra l'effetto di una protezione contro gli accessi ripetuti.

- hydra -l test_user -P passwords.txt 192.168.50.100 -t 1 -V -f ssh

Figura 10 - Test SSH riuscito: individuata la password testpass



6. Installazione e avvio di FTP su Kali

Per la seconda parte ho installato vsftpd dalla distribuzione Kali. Al termine dell'installazione il servizio risultava inattivo, quindi l'ho avviato manualmente. Il controllo successivo ha mostrato lo stato active (running), mentre ss ha confermato che il server era in ascolto sulla porta 21/TCP.

- sudo apt install vsftpd
- sudo systemctl start vsftpd
- sudo systemctl status vsftpd
- sudo ss -lntp | grep ':21'

Figura 11 - Installazione del pacchetto vsftpd su Kali

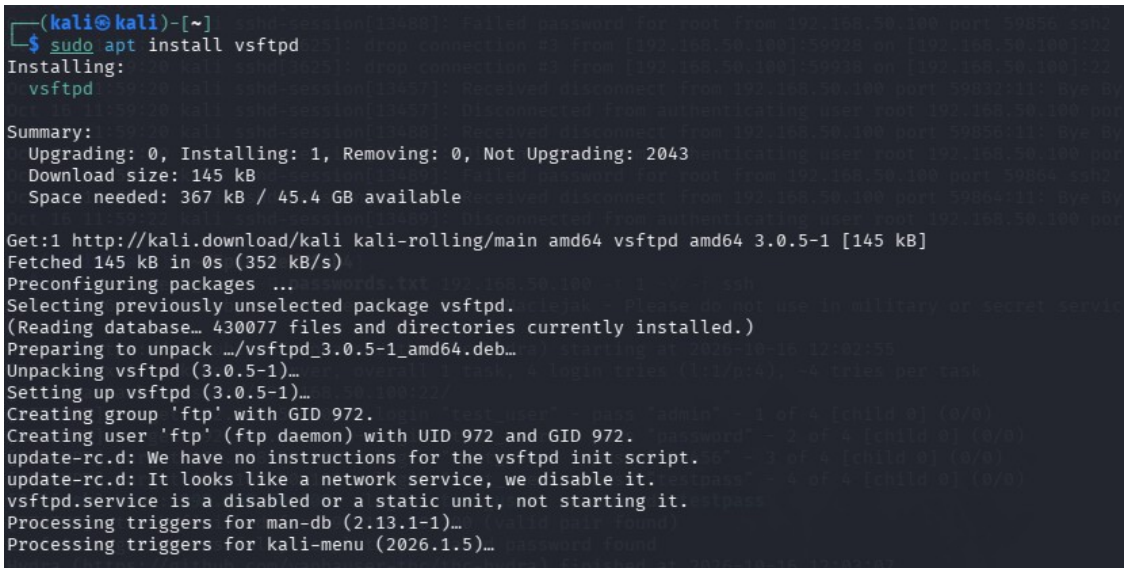


Figura 12 - Stato FTP prima e dopo l’avvio del servizio



Figura 13 - Verifica della porta FTP 21/TCP in ascolto



7. Configurazione e accesso FTP

Ho controllato il file /etc/vsftpd.conf senza modificarlo: la configurazione mostrava anonymous_enable=NO e local_enable=YES. L’accesso anonimo era quindi disabilitato e gli account locali erano abilitati. Prima di usare Hydra ho aperto una connessione FTP con test_user; la risposta 230 Login successful ha confermato la validità delle credenziali.

- sudo grep -nE '^[[:space:]]*(anonymous_enable|local_enable|write_enable|chroot_local_user)[[:space:]]*=' /etc/vsftpd.conf
- ftp 192.168.50.100

Figura 14 - Controllo delle impostazioni di accesso di vsftpd

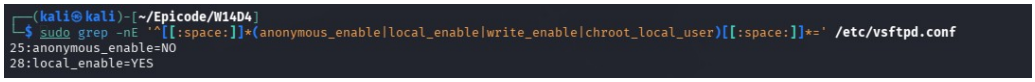


Figura 15 - Accesso manuale FTP riuscito con test_user

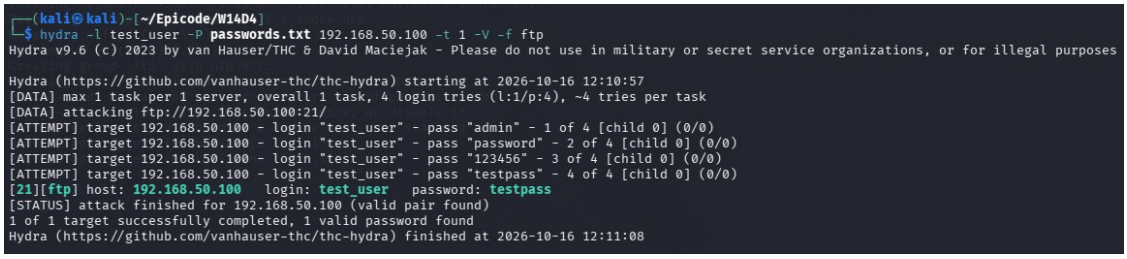


8. Verifica delle credenziali FTP con Hydra

Ho utilizzato lo stesso dizionario di quattro password preparato per SSH, questa volta indicando il protocollo ftp. Hydra ha individuato correttamente la coppia test_user / testpass; il messaggio finale confermava una password valida trovata.

- hydra -l test_user -P passwords.txt 192.168.50.100 -t 1 -V -f ftp

Figura 16 - Hydra individua le credenziali FTP valide su Kali

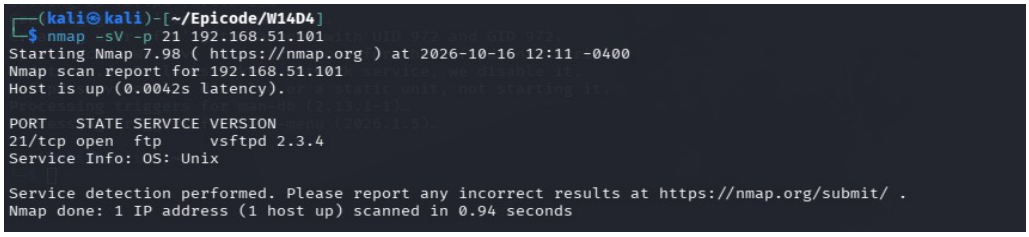


9. Parte facoltativa - Servizio FTP su Metasploitable 2

Per la parte facoltativa ho scelto il servizio FTP presente su Metasploitable 2, con IP 192.168.51.101. La macchina si trova su una sottorete diversa da Kali e comunica con essa tramite pfSense. La scansione Nmap ha identificato la porta 21 aperta e il servizio vsftpd 2.3.4.

- nmap -sV -p 21 192.168.51.101

Figura 17 - Nmap rileva il servizio vsftpd 2.3.4 su Metasploitable



Ho provato l'accesso con le credenziali predefinite della macchina di esercitazione, msfadmin / msfadmin. Anche qui il server ha risposto con 230 Login successful. Ho quindi creato passwords_metasploitable.txt con quattro password, inserendo msfadmin fra i valori da verificare.

- ftp 192.168.51.101
- cat passwords_metasploitable.txt

Figura 18 - Accesso FTP con l'utente msfadmin

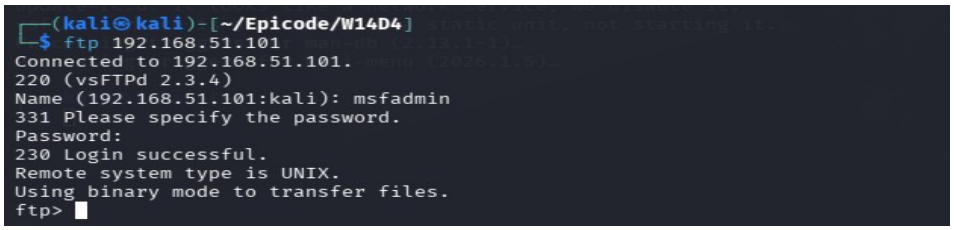


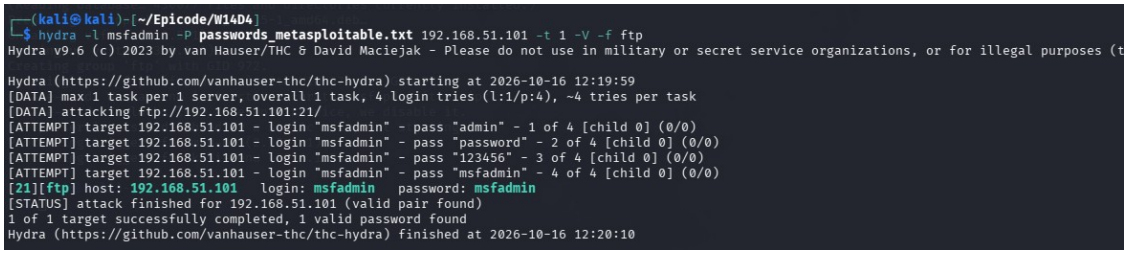
Figura 19 - Wordlist dedicata alla prova su Metasploitable



Per concludere ho avviato Hydra con l'utente msfadmin e la nuova wordlist. Il test si è concluso correttamente: dopo quattro tentativi il programma ha individuato la password msfadmin, confermando la debolezza delle credenziali predefinite.

- hydra -l msfadmin -P passwords_metasploitable.txt 192.168.51.101 -t 1 -V -f ftp

Figura 20 - Test Hydra FTP riuscito su Metasploitable



10. Risultati e considerazioni

Servizio	Macchina e IP	Credenziali individuate	Esito
SSH	Kali - 192.168.50.100	test_user / testpass	Riuscito
FTP	Kali - 192.168.50.100	test_user / testpass	Riuscito
FTP (facoltativo)	Metasploitable - 192.168.51.101	msfadmin / msfadmin	Riuscito

Tutte e tre le verifiche finali hanno trovato le credenziali attese, ma il primo tentativo SSH con quattro connessioni parallele era stato interrotto dalla protezione del server. La prova mostra che anche un dizionario di sole quattro password può bastare quando si usano credenziali semplici o predefinite. In un contesto reale sarebbe importante controllare i tentativi falliti, adottare password robuste e utilizzare meccanismi di protezione per l'autenticazione.

11. Conclusioni

In questo esercizio ho avviato SSH, installato FTP e verificato prima gli accessi manuali, poi le credenziali con Hydra. Il problema incontrato nel primo test SSH è stato utile per capire il comportamento di OpenSSH attraverso i log e correggere l'impostazione della prova senza disabilitare le protezioni.

Con la parte facoltativa ho effettuato la stessa verifica sul servizio FTP di Metasploitable, raggiungendo la macchina attraverso pfSense. Tutte le attività sono state svolte nella rete interna del laboratorio didattico. FTP tradizionale non cifra le credenziali durante la trasmissione; in un ambiente reale preferirei un protocollo sicuro e credenziali non prevedibili.